Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement

Title: Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Overview:

Replacing and modernizing legacy Virtual Private Network (VPN) architectures with a cloud-native Zscaler Zero Trust solution is an approach designed to improve enterprise security, scalability, and user experience. Traditional VPN systems provide broad network access once a user is authenticated, which can increase the risk of cyberattacks, unauthorized access, and lateral movement within the network. These legacy architectures often expand the attack surface because they connect users directly to internal networks, making it easier for attackers to exploit vulnerabilities if credentials are compromised. As organizations adopt cloud services, remote work, and distributed infrastructures, traditional VPN models become less efficient and harder to manage.

The cloud-native Zero Trust architecture offered by Zscaler addresses these challenges by following the principle of "never trust, always verify." Instead of granting full network access, the solution verifies user identity, device posture, and context before allowing access to specific applications. This application-level access ensures that users can only reach the resources they are authorized to use, significantly reducing the risk of lateral movement across the network. By eliminating direct exposure of internal applications to the internet and replacing VPN gateways with secure cloud-based access, the organization can minimize its attack surface while improving performance for remote and hybrid workers.

Additionally, the Zscaler Zero Trust platform provides centralized policy management, real-time monitoring, and advanced threat protection through a globally distributed cloud infrastructure. This allows organizations to scale security without deploying complex on-premises hardware. The project focuses on transitioning from legacy VPN infrastructure to a modern Zero Trust framework, enabling secure, seamless access to applications from any location while strengthening overall cybersecurity posture and operational efficiency.

Abstract:

The increasing reliance on remote access and cloud-based applications has exposed the limitations of traditional Virtual Private Network (VPN) architectures in modern enterprise

environments. Legacy VPN solutions often provide broad network access once a user is authenticated, which increases the attack surface and allows attackers to move laterally within the network if credentials are compromised. This project focuses on replacing and modernizing traditional VPN architectures with a cloud-native Zero Trust security model to enhance organizational security and minimize potential cyber threats.

The project explores the principles of the Zero Trust architecture, which follows the concept of "never trust, always verify." Instead of granting full network access, users are authenticated and authorized based on identity, device posture, and security policies before accessing specific applications. The implementation concept is based on the cloud security platform Zscaler, which enables secure application access without exposing internal networks to the internet. By establishing secure micro-tunnels between users and applications, the solution prevents unauthorized access and reduces the risk of lateral movement within the network.

Additionally, the project includes vulnerability assessment of a web application environment using Nessus to identify potential security weaknesses. The scan was conducted on the demo banking website Altoro Mutual Demo Bank, where several informational vulnerabilities and one low-severity vulnerability were identified. The findings demonstrate how vulnerability scanning helps organizations detect security issues and implement appropriate mitigation strategies.

Overall, this project highlights the importance of modern security frameworks and proactive vulnerability assessment in protecting enterprise systems. By integrating Zero Trust principles with cloud-native security solutions, organizations can significantly reduce their attack surface, enhance access control, and improve overall cybersecurity posture in today's evolving threat landscape.

Use Case Scenarios:

Scenario 1: Remote Employee Access to Internal CRM System

A sales executive working remotely needs to access the company's internal Customer Relationship Management (CRM) system to update customer information and monitor sales progress. The employee connects using a company-issued laptop from a home network. After launching the ZPA Client Connector, the user authenticates through **Microsoft Azure Active Directory** with multi-factor authentication (MFA). ZPA verifies the employee's identity, checks that the user belongs to the Sales_CRM_Users group, and evaluates device posture such as active antivirus, firewall protection, and disk encryption. Once the verification process is complete, ZPA establishes a secure micro-tunnel directly to the CRM application without exposing the corporate network.

Output:

- User authenticated using MFA and identity verification
- Secure micro-tunnel established directly to the CRM system
- Internal network resources remain hidden and inaccessible
- Access granted based on Zero Trust policy enforcement

Scenario 2: Developer Access to Internal Source Code Repository

A software developer needs to access the company's internal source code repository to upload new application updates and review project files. The developer launches the ZPA Client Connector and signs in through Microsoft Azure Active Directory with MFA authentication. ZPA verifies the developer's identity, confirms group membership in the Developers group, and checks the device's security posture including operating system updates and endpoint protection. After validation, ZPA creates a secure micro-tunnel connection only to the internal Git repository server.

Output:

- Developer identity verified with multi-factor authentication
- Secure application-level connection established to the Git repository
- Other internal services such as HR or finance systems remain hidden
- Secure code access without exposing the internal network

Scenario 3: HR Manager Access to Employee Management System

An HR manager needs to review employee records and update personnel information using the company's internal HR management system. The manager accesses the system from a company laptop using the ZPA Client Connector. After authentication through Microsoft Azure Active Directory with MFA, ZPA evaluates the user's role in the HR_Managers group and checks device compliance such as antivirus status and secure configuration. Based on the policy rules, ZPA grants access and establishes a micro-tunnel connection only to the HR application.

Output:

- HR manager authenticated with role-based authorization
- Secure connection established directly to the HR management application
- Sensitive enterprise resources remain isolated
- Access controlled according to Zero Trust policies

Scenario 4: IT Administrator Access to Infrastructure Management Console

An IT administrator must perform maintenance on internal infrastructure systems using a centralized management console. The administrator launches the ZPA Client Connector and logs in using Microsoft Azure Active Directory with MFA and privileged access authentication. ZPA evaluates the administrator's role, confirms membership in the IT_Admin group, and verifies device compliance policies. Once verified, ZPA securely brokers a micro-tunnel connection to the infrastructure management console without exposing other internal applications.

Output:

- Administrator identity validated through strong authentication
- Secure connection created to the management console only
- Access restricted based on administrator privileges
- Other internal applications remain protected and invisible

Scenario 5: Third-Party Vendor Access to Internal Support Portal

A third-party vendor is granted temporary access to the organization's internal support portal to resolve technical issues. Instead of providing full VPN access, the organization uses ZPA to grant application-specific access. The vendor authenticates using federated identity with multi-factor authentication. ZPA evaluates the vendor's permissions and establishes a secure connection only to the support portal. The vendor can troubleshoot issues without gaining visibility into other internal systems.

Output:

- Vendor authenticated with limited access privileges
- Secure application-specific micro-tunnel created to the support portal
- No network-level access granted to internal infrastructure
- Temporary and controlled access enforced through Zero Trust policies

List of teammates:

S.no	Name	College	Contact
2326KA01	Abinaya R	KG College of Arts and Science	9626736440
2326KA02	Adhil Mohammed M	KG College of Arts and Science	894012740
2326KA03	Aiswarya M	KG College of Arts and Science	6369465210
2326KA04	Akshaya B	KG College of Arts and Science	8056731204
2326KA05	Andriya R	KG College of Arts and Science	9345735518

STAGE-1

Top 10 OWASP:

No.	Vulnerability Category	Vulnerability Name	CWE Number
1	Access Control	Broken Access Control	CWE-284
2	Authentication	Identification and Authentication Failures	CWE-287
3	Cryptography	Cryptographic Failures (Sensitive Data Exposure)	CWE-327
4	Injection	SQL Injection	CWE-89

5	Injection	Cross-Site Scripting (XSS)	CWE-79
6	Request Forgery	Cross-Site Request Forgery (CSRF)	CWE-352
7	Configuration	Security Misconfiguration	CWE-16
8	Software Components	Vulnerable and Outdated Components	CWE-1104
9	Integrity	Software and Data Integrity Failures	CWE-494
10	Monitoring	Security Logging and Monitoring Failures	CWE-778
11	Server Vulnerability	Server-Side Request Forgery (SSRF)	CWE-918
12	Information Exposure	Sensitive Information Exposure	CWE-200
13	Transport Security	Insufficient Transport Layer Protection	CWE-319
14	Session Management	Improper Session Management	CWE-613
15	Design Flaws	Insecure Design	CWE-657

Reports:

Vulnerability 1

Vulnerability name: Cross Site Scripting (Stored)

CWE: CWE-79

OWASP category: A03:2021 - Injection

Description: It occurs when a malicious script is injected directly into a vulnerable web application. Stored XSS happens when the malicious script is permanently stored on the target server such as in a database, message forum, or comment field and later executed in users' browsers.

Business Impact: The application stores dangerous data which may execute in user browsers. Attackers may steal session cookies, hijack user sessions, or perform actions on behalf of users.

Vulnerability path: http://testfire.net/

Vulnerability parameter: http://testfire.net/search.jsp?query='><script>alert('hacked')</script>

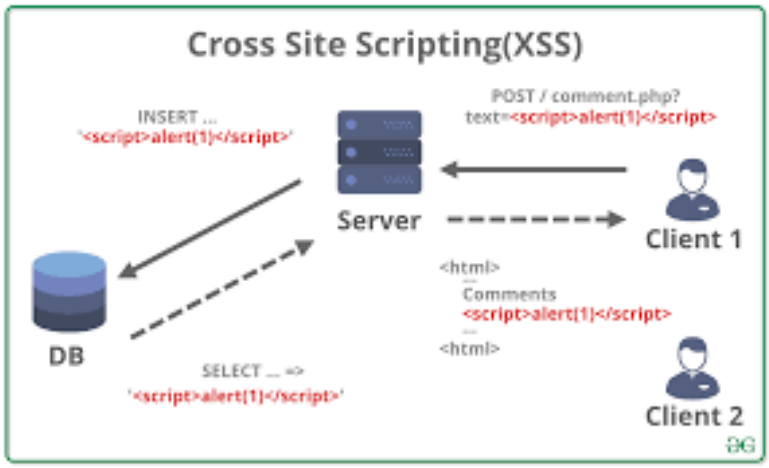
Steps to Reproduce:

- Access the URL
- Enter malicious script in search box
- Use payload '><script>alert('hacked')</script>
- Alert popup appears

Recommendation:

- Sanitize all user inputs
- Use output encoding
- Implement Content Security Policy

Screenshot:



Vulnerability 2

Vulnerability name: SQL Injection

CWE: CWE-89

OWASP category: A03:2021 - Injection

Description: SQL Injection occurs when user input is included in SQL queries without proper validation or escaping.

Business Impact: Attackers can access, modify or delete database data and potentially gain administrator privileges.

Vulnerability path: http://testfire.net/login.jsp

Vulnerability parameter: username=admin' OR '1'='1

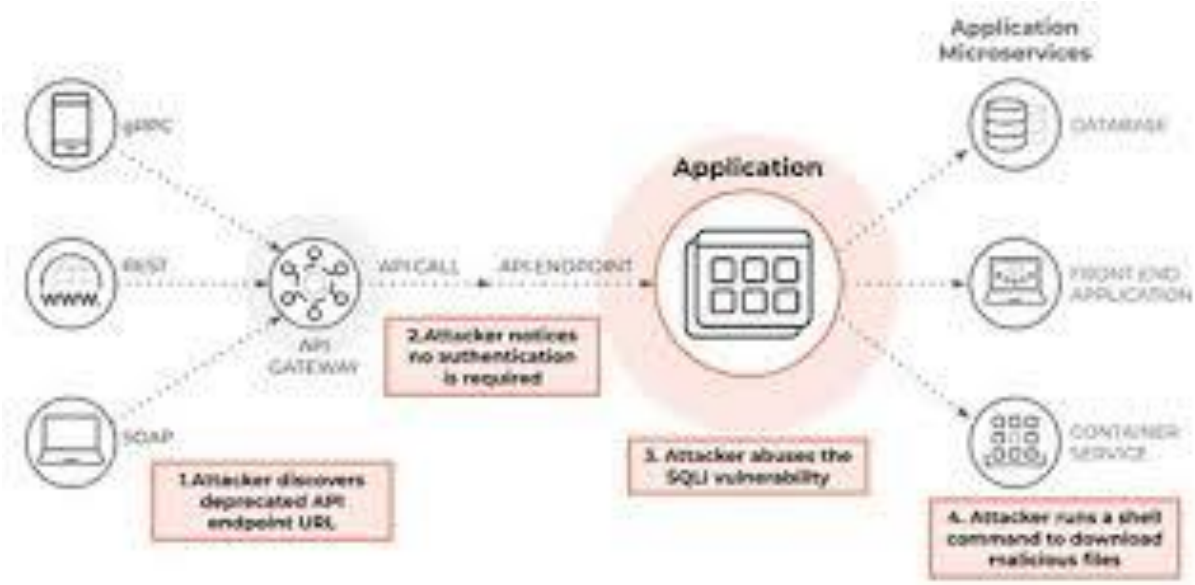
Steps to Reproduce:

- Open login page
- Enter SQL payload in username field
- Submit login request
- Authentication bypass occurs

Recommendation:

- Use prepared statements
- Validate user inputs
- Apply least privilege to DB accounts

Screenshot:



Vulnerability 3

Vulnerability name: Cross Site Request Forgery

CWE: CWE-352

OWASP category: A01:2021 - Broken Access Control

Description: CSRF forces authenticated users to submit unwanted requests to a web application.

Business Impact: Attackers can perform actions like password changes or fund transfers without user consent.

Vulnerability path: http://testfire.net/account.jsp

Vulnerability parameter: transferFunds

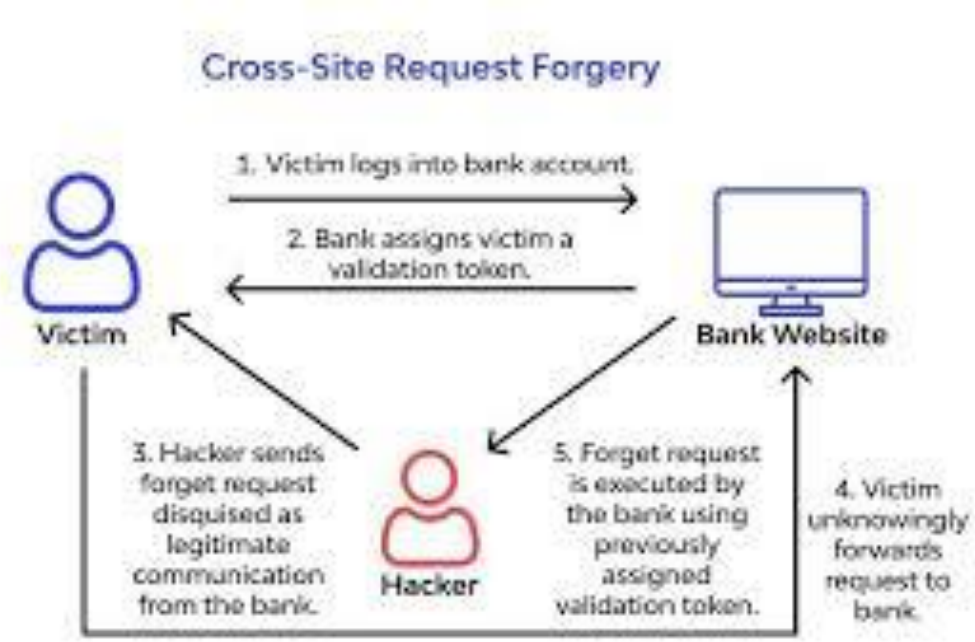
Steps to Reproduce:

- User logs in
- Attacker sends malicious request link
- User clicks while authenticated
- Unauthorized action occurs

Recommendation:

- Use CSRF tokens
- Use same-site cookies
- Verify request origin headers

Screenshot:



Vulnerability 4

Vulnerability name: Sensitive Data Exposure

CWE: CWE-200

OWASP category: A02:2021 - Cryptographic Failures

Description: This occurs when applications fail to properly protect sensitive information such as passwords or credit card data.

Business Impact: Attackers may intercept or steal confidential data leading to financial loss or identity theft.

Vulnerability path: http://testfire.net/profile.jsp

Vulnerability parameter: userDetails

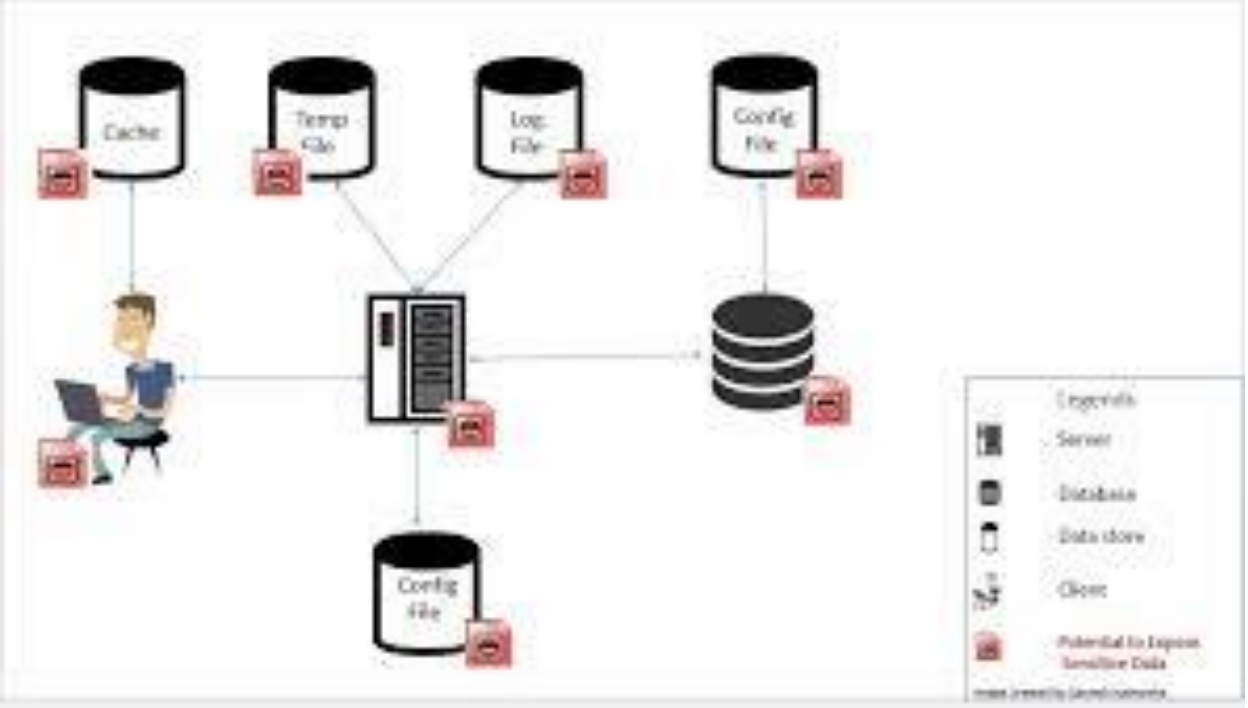
Steps to Reproduce:

- Access profile page
- Observe sensitive data transmitted
- Capture traffic using proxy tool

Recommendation:

- Use HTTPS encryption
- Encrypt sensitive data
- Avoid storing unnecessary sensitive information

Screenshot:



Vulnerability 5

Vulnerability name: Security Misconfiguration

CWE: CWE-16

OWASP category: A05:2021 - Security Misconfiguration

Description: Security misconfiguration occurs when security settings are not properly implemented.

Business Impact: Attackers may exploit exposed services, default credentials, or debug messages.

Vulnerability path: http://testfire.net/admin

Vulnerability parameter: default credentials

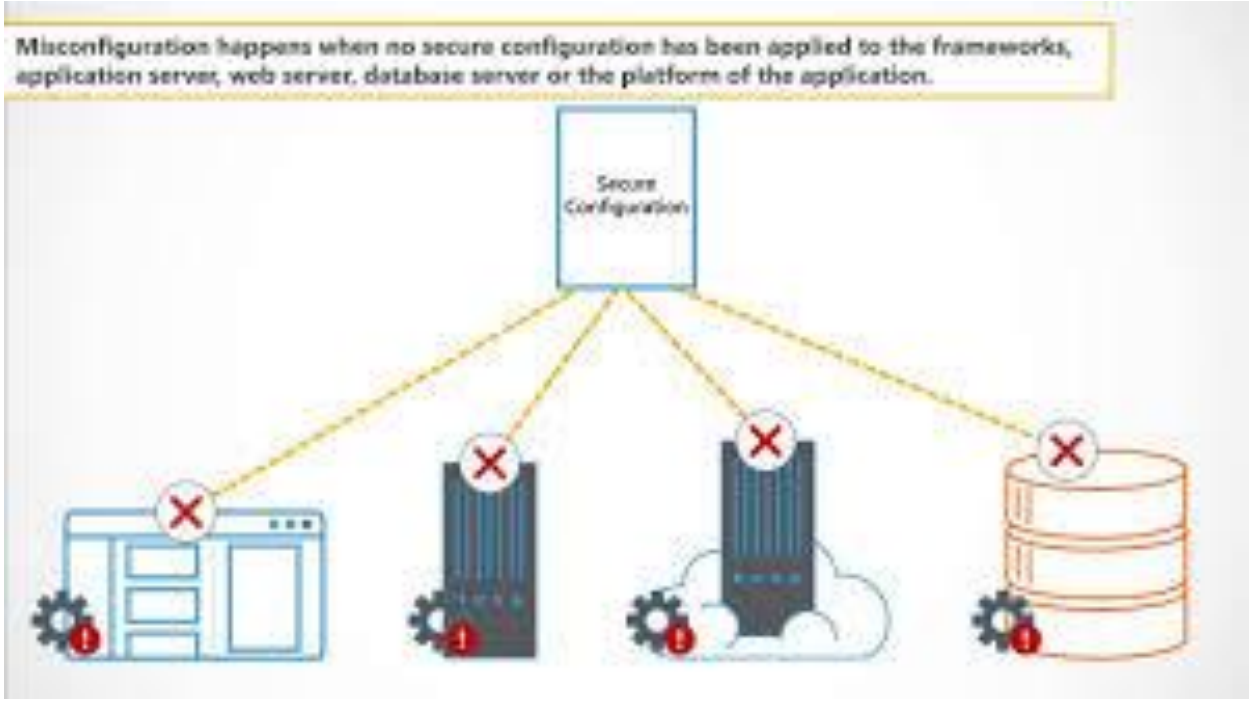
Steps to Reproduce:

- Access admin panel
- Attempt default credentials
- Gain admin access

Recommendation:

- Disable default credentials
- Harden server configurations
- Regular security audits

Screenshot:



Vulnerability 6

Vulnerability name: Broken Access Control

CWE: CWE-284

OWASP category: A01:2021 - Broken Access Control

Description: Access control restrictions are not properly enforced allowing users to access unauthorized resources.

Business Impact: Attackers may access restricted files or perform administrative operations.

Vulnerability path: http://testfire.net/admin/dashboard

Vulnerability parameter: userID=2

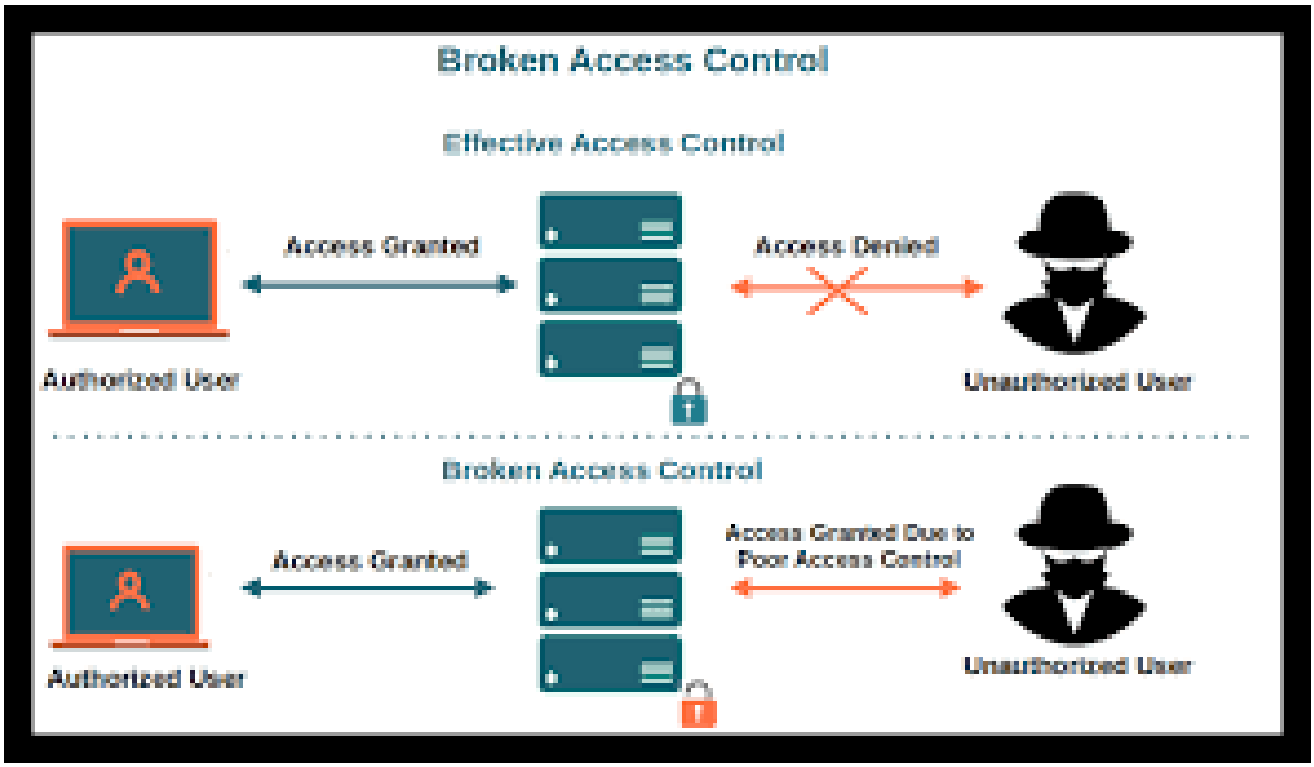
Steps to Reproduce:

- Login as normal user
- Modify URL parameter
- Access admin dashboard

Recommendation:

- Enforce server-side access checks
- Implement role-based access control

Screenshot:



Vulnerability 7

Vulnerability name: Identification and Authentication Failure

CWE: CWE-287

OWASP category: A07:2021 - Identification and Authentication Failures

Description: Improper authentication mechanisms allow attackers to compromise passwords or bypass login systems.

Business Impact: Attackers may take control of user accounts.

Vulnerability path: http://testfire.net/login.jsp

Vulnerability parameter: password guessing

Steps to Reproduce:

- Access login page
- Attempt brute-force login
- Gain account access

Recommendation:

- Use MFA authentication
- Implement account lockout
- Use strong password policies

Screenshot:

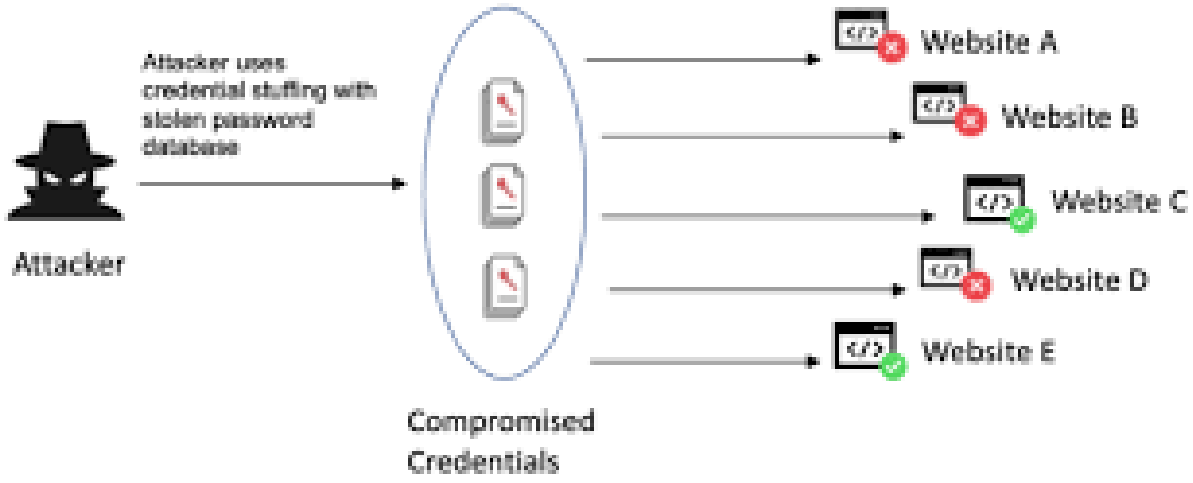


Figure: Identification and authentication failures attack scenario

Vulnerability 8

Vulnerability name: Insecure Direct Object Reference

CWE: CWE-639

OWASP category: A01:2021 - Broken Access Control

Description: This vulnerability occurs when an application exposes internal object references without authorization checks.

Business Impact: Attackers can access other users' data by modifying object identifiers.

Vulnerability path: http://testfire.net/account?id=1001

Vulnerability parameter: id parameter

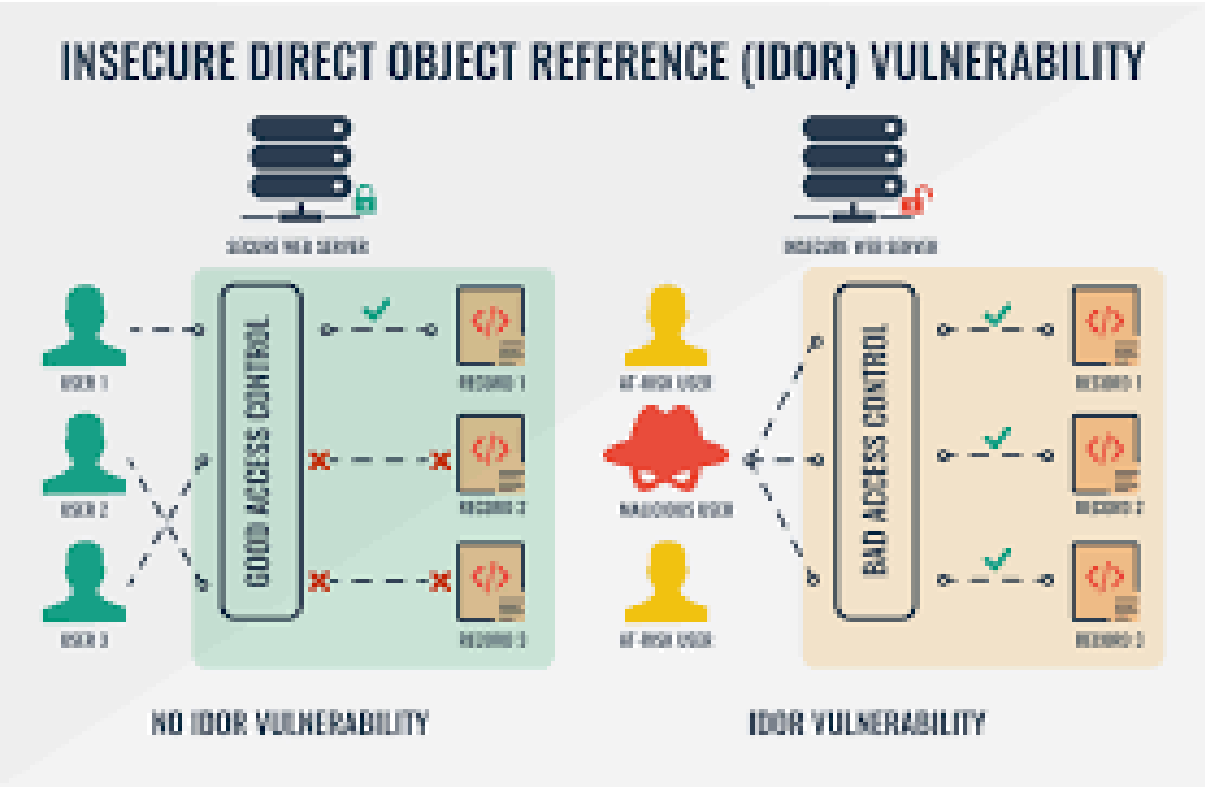
Steps to Reproduce:

- Login to application
- Change ID parameter in URL
- Access another user's data

Recommendation:

- Validate user permissions
- Use indirect object references

Screenshot:



Vulnerability 9

Vulnerability name: Server-Side Request Forgery

CWE: CWE-918

OWASP category: A10:2021 - Server-Side Request Forgery

Description: SSRF allows attackers to force the server to make requests to internal systems.

Business Impact: Attackers may access internal services or sensitive metadata.

Vulnerability path: http://testfire.net/fetch?url=

Vulnerability parameter: url parameter

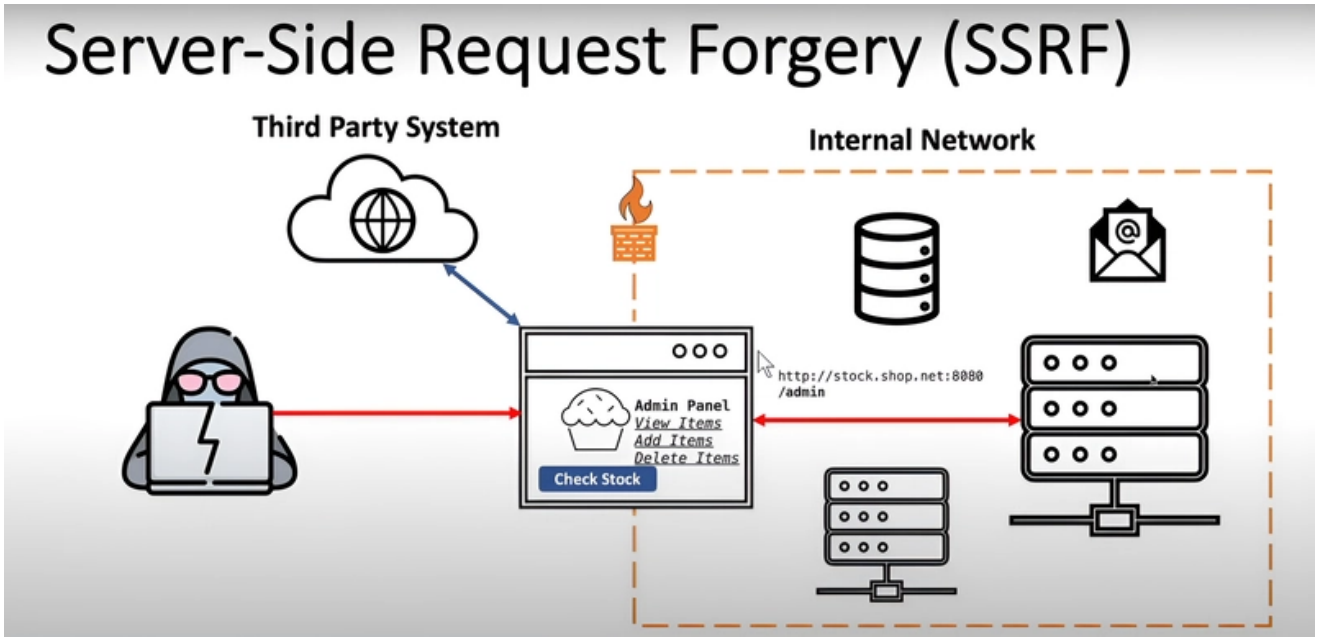
Steps to Reproduce:

- Enter external URL
- Modify request to internal address
- Server fetches internal resource

Recommendation:

- Validate URLs
- Block internal IP ranges
- Use allow lists

Screenshot:



Vulnerability 10

Vulnerability name: Insufficient Logging and Monitoring

CWE: CWE-778

OWASP category: A09:2021 - Security Logging and Monitoring Failures

Description: Applications fail to log security events or monitor suspicious activities.

Business Impact: Attacks may go undetected leading to prolonged system compromise.

Vulnerability path: http://testfire.net/admin/logs

Vulnerability parameter: log monitoring

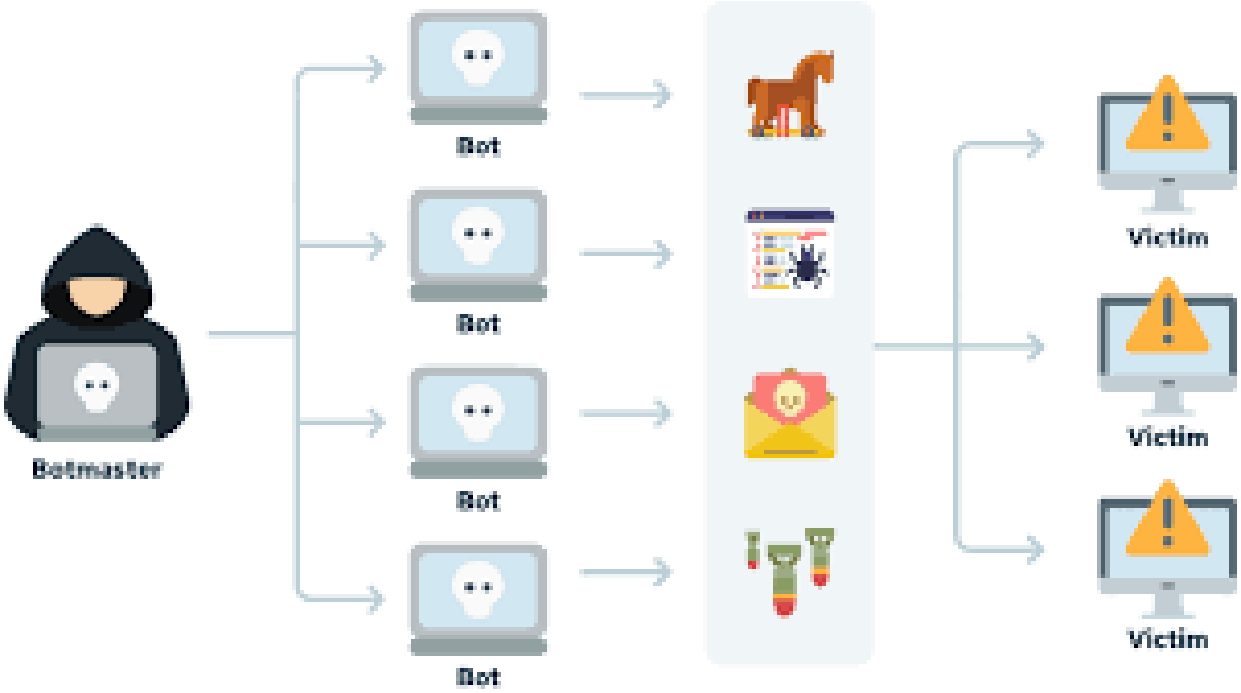
Steps to Reproduce:

- Perform multiple failed logins
- Observe absence of alerts

Recommendation:

- Enable centralized logging
- Monitor suspicious activities

Screenshot:



Vulnerability 11

Vulnerability name: Using Components with Known Vulnerabilities

CWE: CWE-1104

OWASP category: A06:2021 - Vulnerable and Outdated Components

Description: Applications use outdated libraries or frameworks with known security issues.

Business Impact: Attackers may exploit known vulnerabilities in components.

Vulnerability path: http://testfire.net/app

Vulnerability parameter: library version

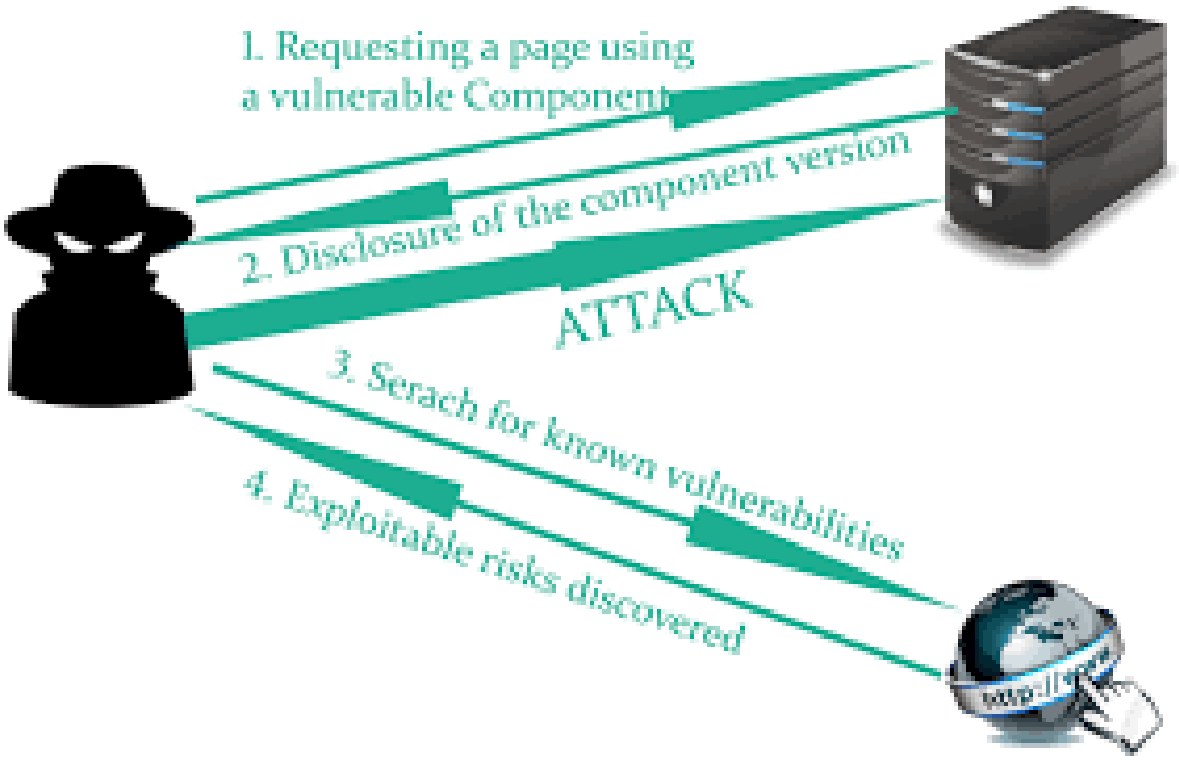
Steps to Reproduce:

- Identify outdated library
- Exploit known vulnerability

Recommendation:

- Update libraries regularly
- Monitor vulnerability databases

Screenshot:



Vulnerability 12

Vulnerability name: Improper Session Management

CWE: CWE-613

OWASP category: A07:2021 - Identification and Authentication Failures

Description: Sessions are not properly managed leading to session hijacking.

Business Impact: Attackers can reuse session IDs to impersonate users.

Vulnerability path: http://testfire.net/session

Vulnerability parameter: sessionID

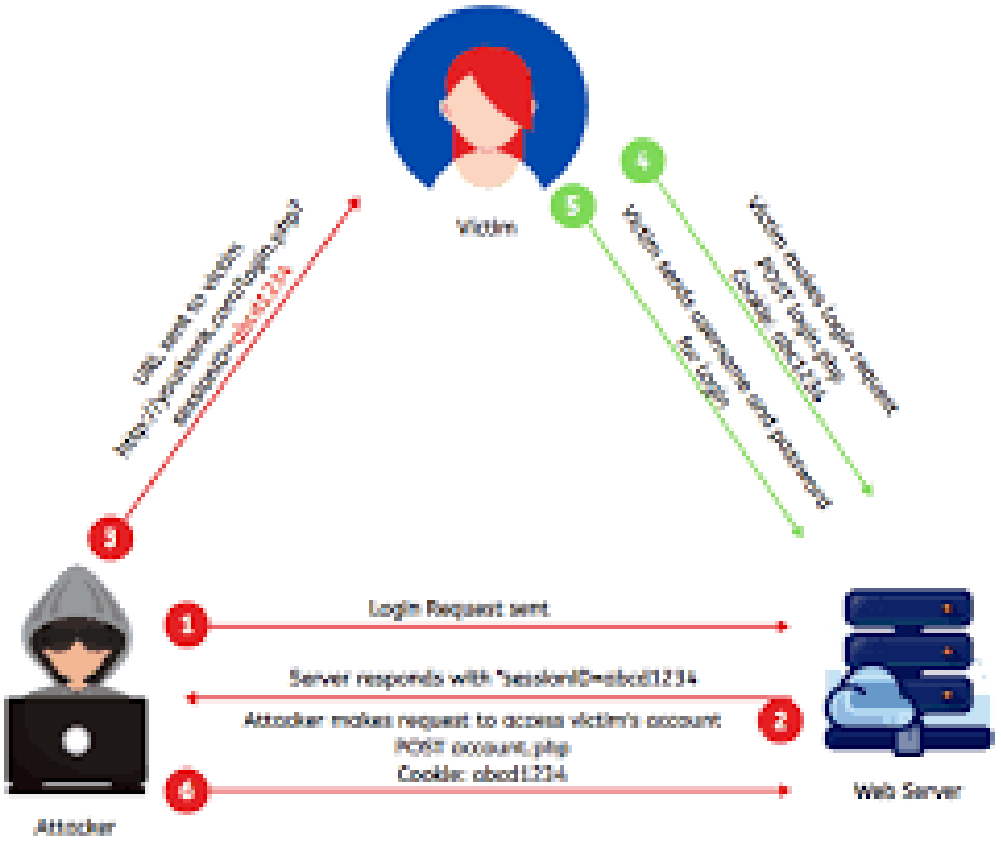
Steps to Reproduce:

- Login to application
- Capture session cookie
- Reuse session cookie

Recommendation:

- Use secure cookies
- Expire sessions after inactivity

Screenshot:



Vulnerability 13

Vulnerability name: Directory Traversal

CWE: CWE-22

OWASP category: A05:2021 - Security Misconfiguration

Description: Attackers manipulate file paths to access restricted files.

Business Impact: Sensitive files such as configuration files may be exposed.

Vulnerability path: http://testfire.net/download?file=

Vulnerability parameter: file=../../etc/passwd

Steps to Reproduce:

- Access download feature
- Modify file path
- Retrieve restricted file

Recommendation:

- Validate file paths
- Restrict directory access

Screenshot:

Vulnerability 14

Vulnerability name: Clickjacking

CWE: CWE-1021

OWASP category: A05:2021 - Security Misconfiguration

Description: Attackers trick users into clicking hidden elements within a webpage.

Business Impact: Users may unknowingly perform sensitive actions.

Vulnerability path: http://testfire.net/transfer

Vulnerability parameter: hidden iframe

Steps to Reproduce:

- Load page inside iframe
- User clicks hidden button

Recommendation:

- Use X-Frame-Options
- Implement frame busting techniques

Screenshot:

Vulnerability 15

Vulnerability name: Insecure Deserialization

CWE: CWE-502

OWASP category: A08:2021 - Software and Data Integrity Failures

Description: Untrusted serialized data is processed leading to code execution.

Business Impact: Attackers may execute arbitrary code or escalate privileges.

Vulnerability path: http://testfire.net/api/deserialize

Vulnerability parameter: serializedObject

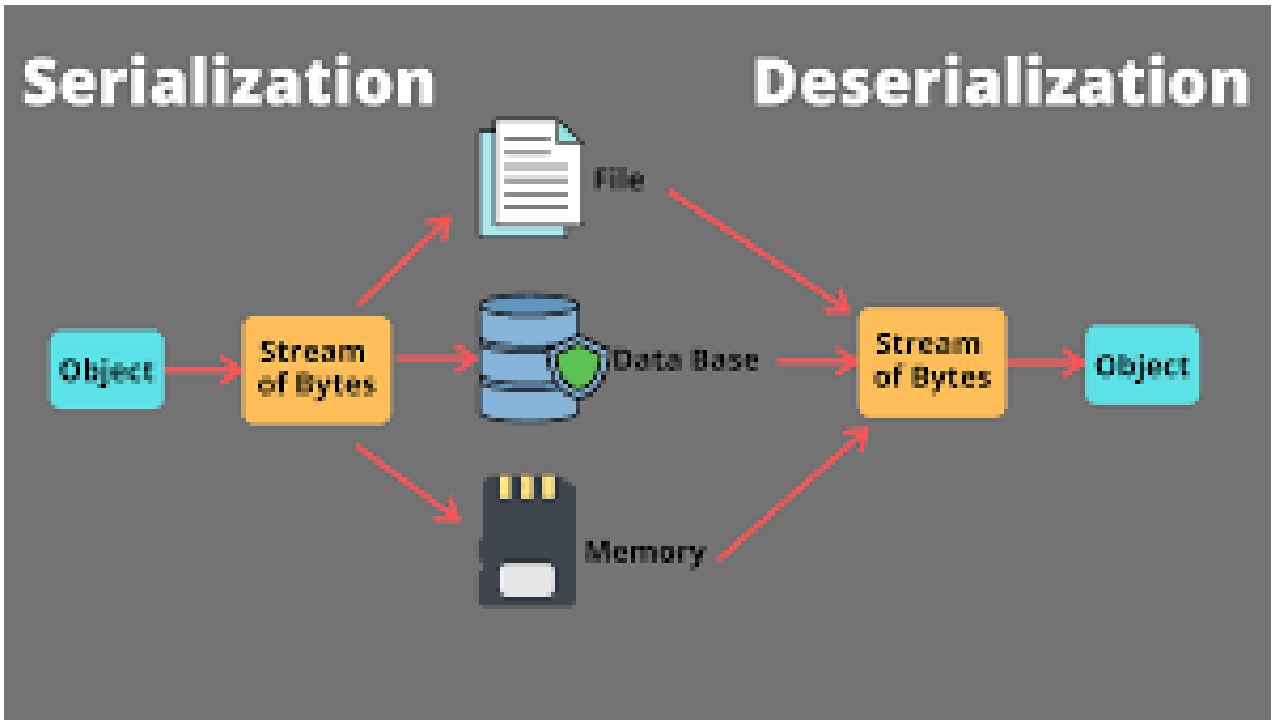
Steps to Reproduce:

- Send crafted serialized object
- Server processes malicious object

Recommendation:

- Validate serialized data
- Avoid deserializing untrusted input

Screenshot:



STAGE-2

Nessus

Overview:

Nessus is a popular vulnerability assessment tool developed by Tenable that is used to identify security weaknesses in computer systems, networks, servers, and web applications. It helps organizations detect vulnerabilities such as outdated software, missing security patches, weak configurations, open ports, and potential malware that attackers could exploit. Nessus works by scanning the target systems and comparing the results with its continuously updated database of known vulnerabilities and security issues.

The tool uses a large collection of plugins to perform different types of security checks and vulnerability tests. These plugins allow Nessus to detect thousands of known vulnerabilities across various operating systems, databases, applications, and network devices. After completing a scan, Nessus generates detailed reports that categorize vulnerabilities based on their severity levels such as critical, high, medium, and low. The reports also include a description of each vulnerability, its potential impact, and recommended solutions or remediation steps to fix the problem.

Nessus supports multiple scanning techniques including network scanning, configuration auditing, malware detection, and web application vulnerability scanning. It also allows users to schedule scans, customize scanning policies, and monitor system security regularly. Because of its high accuracy, user-friendly interface, and regular updates, Nessus is widely used by cybersecurity professionals, penetration testers, and organizations to strengthen their security posture and protect systems from potential cyber threats

use cases of Nessus:

- Vulnerability Assessment
  Nessus is widely used to identify security vulnerabilities in networks, servers, and systems. It scans devices to detect weaknesses such as outdated software, unpatched systems, and insecure configurations that attackers could exploit.
- Network Security Monitoring
  Organizations use Nessus to monitor their network security by scanning routers, switches, firewalls, and other network devices. This helps security teams detect open ports, weak protocols, and other network-related vulnerabilities.
- Compliance Auditing
  Nessus helps organizations meet security compliance requirements such as PCI-DSS, HIPAA, and ISO standards. It checks systems against security policies and compliance guidelines to ensure that organizations follow required security practices.
- Patch Management Support
  Nessus identifies missing patches and outdated software versions on systems. This allows administrators to update and patch their systems quickly to reduce security risks.
- Web Application Security Testing
  Security professionals use Nessus to scan web applications for vulnerabilities like SQL injection, cross-site scripting (XSS), and other common web security issues.
- Configuration Auditing
  Nessus checks system configurations to identify weak settings such as default passwords, unnecessary services, or improper security configurations that could lead to security breaches.
- Penetration Testing Support
  Ethical hackers and penetration testers use Nessus as a reconnaissance tool to gather vulnerability information before performing deeper security testing.

- Risk Management
  Nessus provides vulnerability severity ratings and detailed reports, helping organizations prioritize security issues and fix the most critical vulnerabilities first.

Features of Nessus:

1. **Comprehensive Vulnerability Detection**
   Nessus can detect thousands of vulnerabilities in operating systems, network devices, databases, and web applications. It uses a large and frequently updated plugin database to identify security weaknesses.
2. **High-Speed Asset Discovery**
   The tool quickly scans networks to discover active hosts, open ports, and running services. This helps security teams understand what devices are connected to the network.
3. **Configuration Auditing**
   Nessus checks system configurations and security settings to ensure they follow recommended security standards. It can detect weak configurations such as default credentials or insecure protocols.
4. **Malware Detection**
   Nessus helps identify systems that may be infected with malware or communicating with suspicious or malicious hosts.
5. **Web Application Scanning**
   It scans web applications for common vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), and other security flaws.
6. **Detailed Vulnerability Reports**
   After scanning, Nessus generates detailed reports that include vulnerability descriptions, severity levels (Critical, High, Medium, Low), and recommended solutions.
7. **Customizable Scan Policies**
   Users can create customized scanning policies depending on the network environment and security requirements.
8. **Regular Plugin Updates**
   Nessus receives regular updates from Tenable to detect newly discovered vulnerabilities.

How to Use Nessus

1. **Install Nessus**
   Download and install Nessus from the official website of Tenable. It is available for Windows, Linux, and macOS systems.
2. **Activate the Tool**
   After installation, activate Nessus using an activation code provided during registration.

3. **Access the Web Interface**
   Nessus runs through a web-based interface. Open a browser and access it using: https://localhost:8834
4. **Create a New Scan**
   Click **New Scan** and choose a scan template such as **Basic Network Scan**.
5. **Configure the Scan**
   Enter the **target IP address or domain name** of the system you want to scan and configure scan settings if required.
6. **Run the Scan**
   Start the scan. Nessus will analyze the target system and check for vulnerabilities.
7. **Review the Results**
   After the scan is completed, Nessus displays the vulnerabilities found along with their severity levels.
8. **Generate Reports**
   Export the scan results as reports (PDF, HTML, or CSV) for documentation and further security analysis.

Target website: https://demo.testfire.net/

Target ip address: 65.61.137.117

S.No	Vulnerability Name	Severity	Plugin Id
1	ICMP Timestamp Request Remote Date Disclosure	Low	10114
2	HTTP (Multiple Issues)	Info	10107
3	Service Detection	Info	22964
4	Apache Tomcat Detection	Info	39446
5	Nessus SYN Scanner	Info	11219
6	Common Platform Enumeration (CPE)	Info	45590
7	Device Type	Info	54615
8	Nessus Scan Information	Info	19506
9	OS Fingerprints Detected	Info	209654
10	OS Identification	Info	11936

Report:

1. ICMP Timestamp Request Remote Date Disclosure

Vulnerability Name:- ICMP Timestamp Request Remote Date Disclosure
Severity :- Low
Plugin :- 10114
Port :- ICMP
Description:-
The remote host responds to ICMP timestamp requests. This may allow an attacker to determine the system's internal clock information and calculate the time difference between the target system and the attacker. Although this does not directly compromise the system, it can assist attackers in network reconnaissance and time-based attacks.

Solution:-
Disable ICMP timestamp responses on the system firewall or network devices to prevent external users from retrieving system time information.

Business Impact:-
Attackers may use the exposed time information to perform network reconnaissance or coordinate further attacks. While the risk is low, it may provide useful information that can assist in planning targeted attacks.

2. HTTP (Multiple Issues)

Vulnerability Name:- HTTP (Multiple Issues)
Severity :- Info
Plugin :- 10107
Port :- 80
Description:-
The web server is configured using HTTP protocol and may contain multiple informational issues such as missing security headers, banner disclosure, or configuration weaknesses detected during scanning.

Solution:-
Configure the web server securely by enabling proper HTTP security headers, hiding server version information, and applying recommended web server hardening practices.

Business Impact:-
Information disclosure may provide attackers with details about the web server configuration, which could help them identify possible vulnerabilities.

3. Service Detection

Vulnerability Name:- Service Detection
Severity :- Info
Plugin :- 22964
Port :- Multiple Ports
Description:-
The scanner detected services running on the target host. Service detection identifies the applications and protocols operating on open ports.

Solution:-
Ensure that only required services are running and close or disable unnecessary ports and services.

Business Impact:-
Exposed services increase the potential attack surface and may allow attackers to target known vulnerabilities in those services.

4. Apache Tomcat Detection

Vulnerability Name:- Apache Tomcat Detection
Severity :- Info
Plugin :- 39446
Port :- 8080 / Web Server Port
Description:-
The scan detected that the target web server is running Apache Tomcat. This information is useful for identifying the underlying server technology.

Solution:-
Ensure Apache Tomcat is updated to the latest version and configured securely with proper authentication and access controls.

Business Impact:-
Attackers can use server technology information to search for known vulnerabilities associated with that specific software.

5. Nessus SYN Scanner

Vulnerability Name:- Nessus SYN Scanner
Severity :- Info
Plugin :- 11219
Port :- Multiple Ports
Description:-
This plugin reports that the Nessus SYN scanner was used to identify open ports on the target system using TCP SYN scanning technique.

Solution:-
Restrict unnecessary ports using firewall rules and implement network monitoring to detect suspicious scanning activity.

Business Impact:-
Open ports may expose services that attackers could exploit if vulnerabilities exist in those services.

6. Common Platform Enumeration (CPE)

Vulnerability Name:- Common Platform Enumeration (CPE)
Severity :- Info
Plugin :- 45590
Port :- General
Description:-
The scan detected platform information using the Common Platform Enumeration (CPE) standard. This identifies the operating system and software products running on the target system.

Solution:-
Ensure all detected software components are regularly updated and patched to reduce security risks.

Business Impact:-
If attackers know the platform and software versions, they may search for known vulnerabilities associated with them.

7. Device Type

Vulnerability Name:- Device Type
Severity :- Info
Plugin :- 54615
Port :- General
Description:-
The scanner identified the type of device being scanned, such as a web server or network device.

Solution:-
Limit information disclosure and configure systems to avoid revealing device type information externally.

Business Impact:-
Device identification may help attackers determine the most suitable attack techniques for that device.

8. Nessus Scan Information

Vulnerability Name:- Nessus Scan Information
Severity :- Info
Plugin :- 19506
Port :- General
Description:-
This plugin provides information about the scan configuration, including the scanning engine and scan settings used during the vulnerability assessment.

Solution:-
No direct remediation required as this is informational.

Business Impact:-
No direct security impact; this information is mainly used for reporting and auditing purposes.

9. OS Fingerprints Detected

Vulnerability Name:- OS Fingerprints Detected
Severity :- Info
Plugin :- 209654
Port :- General
Description:-
The scanner detected operating system fingerprints from the target host by analyzing network responses.

Solution:-
Configure systems and firewalls to limit OS fingerprinting techniques where possible.

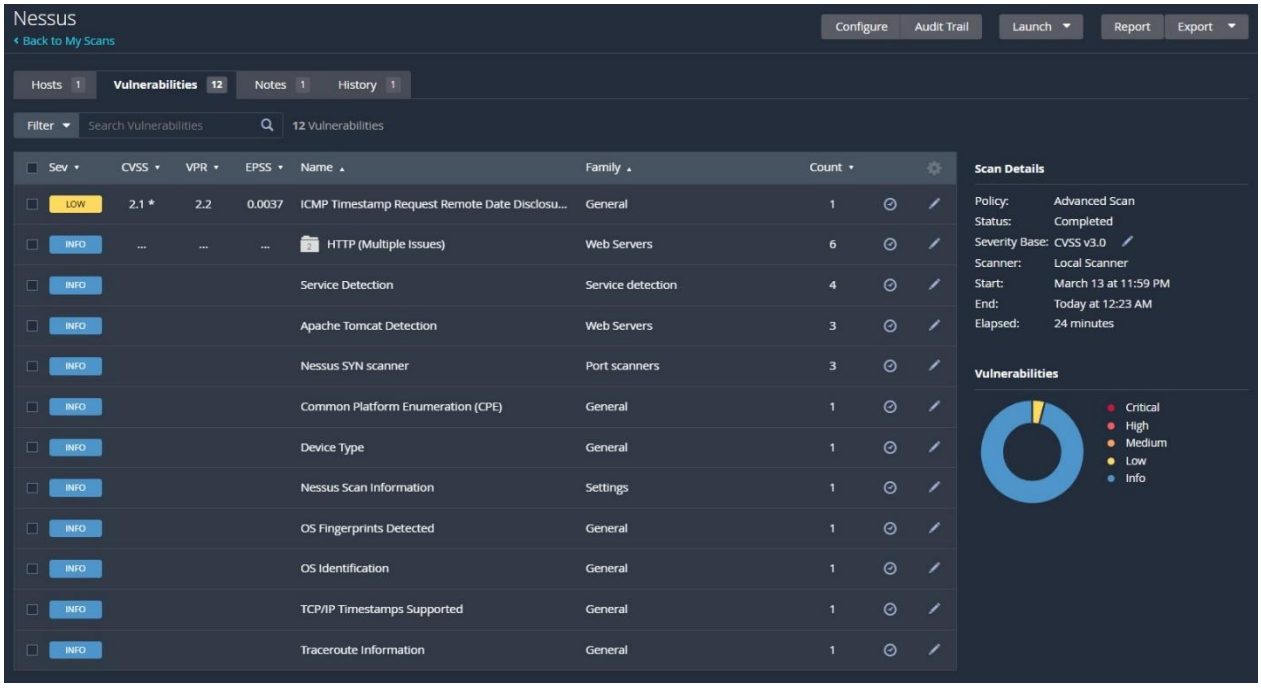
Business Impact:-
If attackers identify the operating system, they can search for vulnerabilities specific to that OS.

10. OS Identification

Vulnerability Name:- OS Identification
Severity :- Info
Plugin :- 11936
Port :- General
Description:-
The scanner identified the operating system running on the target host through network behavior and service responses.

Solution:-
Reduce OS information disclosure and ensure the system is patched with the latest security updates.

Business Impact:-
Operating system identification can help attackers plan targeted attacks using known vulnerabilities.



STAGE-3

REPORT

Title: Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

1. Limitations of Traditional VPN Architectures

Traditional Virtual Private Network (VPN) solutions were originally designed to provide remote users with secure access to internal corporate networks. However, these systems often grant broad network-level access once a user is authenticated, which increases the organization's attack surface. If an attacker gains access to a compromised account, they may move laterally across the network and access multiple internal resources. Additionally, legacy VPN systems require complex infrastructure, constant maintenance, and may suffer from performance bottlenecks when supporting large numbers of remote users. These limitations highlight the need for a more secure and scalable access model.

2. Zero Trust Security Model and Principles

The **Zero Trust** security model is based on the principle of **"never trust, always verify."** Instead of trusting users simply because they are inside the network, every access request must be authenticated, authorized, and continuously validated. The Zero Trust approach focuses on identity verification, device posture checks, least-privilege access, and continuous monitoring.

By implementing these principles, organizations can ensure that users only access the applications and resources necessary for their role, reducing the chances of unauthorized access and internal threats.

3. Cloud-Native Secure Access with Zscaler

A cloud-native Zero Trust platform like Zscaler enables secure application access without exposing internal networks to the internet. Instead of connecting users to the network, Zscaler securely connects users directly to specific applications using encrypted micro-tunnels. This approach eliminates the need for traditional VPN gateways and reduces infrastructure complexity. Zscaler's globally distributed cloud platform also provides real-time threat protection, policy enforcement, and secure access for users working from any location or device.

4. Reducing Attack Surface and Preventing Lateral Movement

One of the main benefits of implementing Zero Trust architecture is the reduction of the organization's attack surface. Since applications are not directly exposed to the internet and users are only granted application-level access, attackers cannot easily scan or discover internal systems. Even if an account is compromised, the attacker cannot move laterally within the network because access is restricted by strict security policies. This significantly improves the organization's cybersecurity posture and helps protect sensitive business data.

Conclusion:

Stage 1 Conclusion

In Stage 1, the project focused on understanding the security challenges associated with traditional VPN architectures and the importance of adopting a modern security model. The study highlighted how legacy VPN systems expose organizations to cyber threats such as unauthorized access, lateral movement, and increased attack surface. By analyzing common web vulnerabilities like SQL Injection, Cross-Site Scripting (XSS), CSRF, and others based on OWASP standards, this stage provided a strong foundation in web application security. The vulnerability assessment of the test environment helped demonstrate how attackers can exploit insecure applications and emphasized the importance of implementing secure coding practices and proper security configurations.

Stage 2 Conclusion

Stage 2 focused on performing vulnerability assessment using the **Nessus** security scanning tool. The scanning process was conducted on the target website **Altoro Mutual Demo Bank** to identify potential security weaknesses. The scan results revealed several informational findings and one low-severity vulnerability related to ICMP timestamp disclosure. This stage demonstrated how automated vulnerability scanners help security professionals detect system weaknesses, analyze network services, and identify configuration issues. The generated reports provided detailed descriptions, severity levels, and remediation recommendations, which are essential for improving system security.

Stage 3 Conclusion

Stage 3 focused on studying the implementation of a **Zero Trust security architecture** using a cloud-based solution such as **Zscaler**. The study highlighted how Zero Trust principles such as identity verification, device posture checking, and least-privilege access can effectively replace traditional VPN architectures. By allowing users to access only specific applications instead of the entire network, Zero Trust significantly reduces the attack surface and prevents lateral movement within enterprise environments. The analysis of different use-case scenarios demonstrated how secure remote access can be achieved while maintaining strong security controls. Overall, this stage emphasized the importance of modern cloud-based security solutions in protecting enterprise networks.

Future Scope:

Stage 1 Future Scope

In the future, the project can be expanded by performing deeper penetration testing using advanced tools and techniques. Additional vulnerability categories from the OWASP Top 10 can be explored to identify complex security issues in modern web applications. The project can also include automated vulnerability detection systems and secure coding practices to prevent vulnerabilities during the development phase. Integrating security testing into the software development lifecycle (SDLC) will further improve application security.

Stage 2 Future Scope

Future work can include performing more advanced vulnerability scanning using multiple security tools such as **OpenVAS**, **Burp Suite**, and **Nikto**. Continuous vulnerability monitoring and automated patch management can also be implemented to strengthen system security. In

addition, integrating vulnerability scanning with Security Information and Event Management (SIEM) systems will allow organizations to detect and respond to threats more effectively.

Stage 3 Future Scope

Future improvements can involve implementing a full Zero Trust architecture in real enterprise environments. The project can also explore advanced security technologies such as micro-segmentation, behavioral analytics, and artificial intelligence-based threat detection. Integration with identity management systems and cloud security platforms can further enhance security. Additionally, implementing **Zero Trust Network Access (ZTNA)** solutions in large-scale organizations will help provide secure access to cloud applications and enterprise resources

Topics Explored

- Zero Trust Security Architecture
- Limitations of Traditional VPN Systems
- Web Application Vulnerabilities (OWASP Top 15)
- Vulnerability Assessment and Risk Analysis
- Network Security and Access Control
- Secure Remote Access Technologies
- Cloud-based Security Solutions
- Application-level Access Control and Micro-Segmentation

Tools Explored

- **Nessus** – Vulnerability scanning and security assessment
- **Kali Linux** – Penetration testing environment
- **Burp Suite** – Web application security testing
- **OWASP ZAP** – Automated web vulnerability scanner
- **Zscaler Platform – Zero Trust secure access implementation